חלק א': שאלה פתוחה - 28 נקודות

בחלק זה שאלה אחת. יש להשיב **במקום המיועד בטופס הבחינה בלבד**.

(התשובות כאן מתומצתות. במבחן יש לענות תשובות מלאות ומנומקות)

א. נתונה הפונק' foo(i,s) אשר מוגדרת כך: בהינתן מחרוזת s אשר מורכבת כולה מתווים מתוך האלפבית

a-z, הפונק' מחזירה את המיקום באלפבית של התו במקום i במחרוזת s.

למשל, הפעלת foo(i,'abcd') עם i=0 תחזיר 0, עם i=1 תחזיר 1 וכו', כי a הוא התו הראשון באלפבית וכו'.

(שימו לב, הפונק' מחזירה את המיקום <u>באלפבית</u> **ולא** במחרוזת)

מציעים להשתמש בפונק' hash הבאה:

$$h(x) = \left[\sum_{i=0}^{|x|-1} foo(i,x) \right] mod 26$$

האם פונק' ה hash הזו בטוחה? נמקו.

<u>תשובה:</u>

לפונק' יש רק 26 פלטים אפשריים, מה שמאפשר לסתור את תכונות הבטיחות הנדרשות מפונק' hash בקלות על ידי מציאת התנגשות. כתוצאה מכך, למשל, אם היו משתמשים בפונק' זו כדי לאמת אותנטיות של קובץ, תוקף היה בקלות יכול לשנות את הקובץ שיכיל קוד זדוני כאוות נפשו ועדיין ה digest עליו ייתנגש עם הdigest על הקובץ המקורי.

ב. אליס מציעה להשתמש ב mode of operation הבא עבור צופן בלוקים.

נתון צופן בלוקים E ידוע ותקין (למשל AES), ונתון מפתח אקראי ותקין K.

כאשר רוצים להצפין הודעה M, מחלקים אותה לבלוקים M2,M1,.. וכו'.

בוחרים מחרוזת אקראית C0, ולכל i>0 מצפינים את הבלוק Mi באופן הבא: $C_i = C_{i-1} \bigoplus E_K(M_i)$

ה ciphertext המתקבל הוא: $C = C_0 || C_1 || C_2 || \dots$

האם ה operation of mode המוצע בטוח? נמקו.

<u>תשובה:</u>

לא.
<u>בשונה</u> מ CBC, כאן הבלוק הקודם עובר xor עם <u>הפלט</u> של ההצפנה של הבלוק.
(ב CBC הבלוק הקודם עובר xor עם <u>הקלט</u> להצפנה)
ולכן, בלוקים זהים בקלט - הפעלת פונק׳ E עליהם תייצר אותו פלט (בדומה לבעיה שראינו ב ECB).

ג. אליס החליטה לממש בעצמה קליינט ביטקוין שיוכל לבדוק את תקינות הבלוקצ'יין כל הזמן – זאת מטרתו.

(למשל, הוא לא צריך לדעת לייצר טרנזקציות חדשות עבור משתמשים – כי זה לא נצרך להשגת מטרתו, אבל כן צריך לדעת, למשל, לבדוק בלוקים חדשים שהוא שומע עליהם – כי זה כן נצרך להשגת מטרתו.)

אליס החליטה לבצע את השיפור הבא.

הקליינט שלה לא שומר את כל הבלוקצ'יין, אלא רק:

- את הבלוק האחרון ביותר בבלוקצ'יין.
- רשימה של כל הטרנזקציות שלא בוזבזו עדיין. נקרא לרשימה זו tran.

עם זאת, בעת קבלת בלוק חדש, הקוד של אליס עושה את כל הבדיקות הסטנדרטיות שקוד הביטקוין הרגיל עושה, למשל:

- בודק שהבלוק החדש הוא אכן הבלוק הבא בתור.
- בודק את תקינות הקריפטוגרפיה (למשל, את ה hash של הבלוק).
- בודק שכל הטרנזקציות בבלוק תקינות (למשל, הן מבזבזות טרנזקציות שמופיעות tran.)
- וכו'

אם כל הבדיקות עוברות בהצלחה, הקליינט של אליס מעדכן אצלו את הבלוק האחרון להיות הבלוק החדש ומעדכן את tran (מוסיף טרנזקציות חדשות ומוחק טרנזקציות שבוזבזו.)

נתון כי הקליינט של אליס וידא את תקינות הבלוקצ'יין הקיים עד לרגע זה, ומעתה והלאה, עובד לפי הלוגיקה שתוארה לעיל.

האם מימוש הקליינט שתואר לעיל תקין או בעייתי?

אם הוא בעייתי, הסבירו מדוע (מה הבעיה) ותארו תרחיש בעייתי מתאים.

אם המימוש תקין, הסבירו מדוע.

<u>תשובה:</u>

המימוש בעייתי.
במידה ומתרחש פיצול (fork), הקליינט בוחר את אחת מהשרשראות.
כתוצאה מכך, הוא ממשיך לעבוד עליה, מה שמשנה את הטרנזקציות שיש ב tran בהתאם.
במידה והפיצול שהוא עבד עליו נזנח ולא נוצר סביבו קונצנזוס, לקליינט אין את רשימת הטרנזקציות המתאימות ב tran כדי לאמץ את הבלוק האחרון בשרשרת שנוצרה סביבה קונצנזוס ולכן לא יכול להמשיך ולוודא את תקינות הבלוקצ׳יין. הקליינט יקבל בלוקים שלא מסתדרים עם המידע שיש לו לגבי הבלוק האחרון.

ד. נתון מנגנון הסכמה על מפתח סימטרי מבוסס Diffie-Hellman.

נתון שאליס ובוב יצרו מבעוד מועד כל אחד זוג מפתחות פרטי/פומבי, ושכל אחד יודע את המפתח הפומבי של השני. (הניחו שהמפתחות תקינים ושאליס ובוב אכן למדו את המפתח הפומבי הנכון אחד של השני).

אליס ובוב מסכימים על מפתח סימטרי באופן הבא.

אליס ובוב מבצעים Diffie-Hellman סטנדרטי ביניהם עם שינוי אחד – במקום שאליס תשלח לבוב את תוצאת החישוב שלה, היא מצפינה את תוצאת החישוב בעזרת המפתח הפומבי של בוב ואז שולחת את ה ciphertext המתקבל, ובוב מפענח את ה ciphertext עם המפתח הפרטי שלו וממשיך כרגיל. באופן זהה, בוב מצפין את תוצאת החישוב שלו עם המפתח הפומבי של אליס, שולח את ה ciphertext המתקבל לאליס, ואליס מפענחת עם המפתח הפרטי שלה וממשיכה כרגיל.

האם השיטה הנ"ל טובה?

אם כן – הסבירו מדוע.

אם לא – הסבירו מדוע והראו התקפה בה תוקף יוכל להאזין למידע שמוצפן באמצעות מפתח סימטרי אשר נשלח בין אליס ובוב לאחר שהסכימו על מפתח סימטרי בעזרת הפרוטוקול הנ"ל.

<u>תשובה:</u>

נשים לב שב DH רגיל המידע שמוצפן לעיל עובר באופן חשוף, כך שהוא אינו סודי בגלל בעיית הלוגריתם הדיסקרטי. אבל, ראינו שהמנגנון חשוף להתקפת MITM.
כאן, לתוקף אין יותר מידע מהמנגנון הרגיל - אלא פחות.
יתרה מכך, התוקף כעת בבעיה לבצע את ה MITM של DH הרגיל, כי אומנם התוקף יכול להצפין ולשלוח לאליס איזה ערך שירצה כאילו הוא בוב, כאשר אליס שולחת כעת את הערך שיצא לה, היא מצפינה אותו עם ה pk של בוב.
מכיוון שלתוקף אין את הsk של בוב, התוקף אינו יכול לפענח את המידע שאליס שלחה - ולא יכול להשלים את חישוב המפתח הסימטרי שיצא לאליס.

חלק ב': שאלות ברירה - 72 נקודות

בחלק זה 12 שאלות. משקל כל שאלה 6 נקודות. יש להשיב על כל השאלות. יש לסמן את התשובה הנכונה ביותר, בעט שחור או כחול בלבד באופן ברור ועל פי ההנחיות, **בדף הקידוד המצורף בלבד**.

(בכל השאלות כאן תשובה א היא התשובה הנכונה)

<u>שאלה מספר 1:</u>

נתונה חומת אש על התעבורה הנכנסת אל רשת מסויימת ויוצאת מהרשת החוצה, כאשר חומת האש <u>אינה</u> עובדת בשכבת האפליקציה.

איזו מבין ההתקפות הבאות חומת אש שכזו <u>כן</u> מגינה מפניה?

א. התקפה המבצעת spoofing

ב. התקפה המתבצעת ע"י אימייל המכיל קוד זדוני

ג. התקפה המנצלת חולשה במימוש של חומת האש

ד. התקפה בה התוקף נמצא בתוך הרשת והוא תוקף מחשב אחר ברשת

<u>שאלה מספר 2:</u>

להלן טענות לגבי DoS. איזו מבין הטענות נכונה?

א. התקפת slow loris מחזיקה הרבה חיבורי http פתוחים כמה זמן שהיא יכולה

ב. מטרת התקפות Syn flood היא לפגוע בשרת המותקף על ידי העמסה על רוחב הפס שלו

ג. ראשי התיבות DoS הן של התקפות Disk on Stack

ד. התקפות DoS נעשות אך ורק בשכבה הפיזית, הלינק, התעבורה והרשת

<u>שאלה מספר 3:</u>

איזו מבין הטענות הבאות <u>אינה</u> נכונה?

א. אם ימציאו חומרה היכולה לבצע את כל פעולות הקריפטוגרפיה באפס זמן (כלומר, שביצוע פעולות קריפטו לא "עולה" שום זמן), הורדת עמוד אינטרנט על גבי HTTPS יקח אותו משך זמן כמו הורדת אותו העמוד על גבי HTTP רגיל

ב. בTLS, משתמשים במפתחות שונים להצפין תעבורה הנשלחת מהשרת ללקוח לעומת תעבורה הנשלחת מהלקוח לשרת

ג. בTLS משתמשים בהצפנה סימטרית וגם בהצפנה א-סימטרית

ד. בTLS לקוח הגולש לשרת foo.com מוודא את תקינות התעודה שקיבל כחלק מתהליך הקמת החיבור המוצפן

<u>שאלה מספר 4:</u>

איזו מבין הטענות הבאות <u>אינה</u> נכונה?

א. אחת מהדרכים להגן מפני התקפת cross-site request forgery היא בעזרת csrf token. הגנה זאת מבקשת מהמשתמש להזין ידנית קוד מיוחד לשדה הזנת טקסט ייעודי באתר

ב. ב XSS מסוג DOM based החולשה נמצאת בקוד שרץ בצד הקליינט

ג. התקפת cross-site request forgery בנויה על כך שהדפדפן מצרף cookies לבקשות

ד. בהתקפת cross-site request forgery השרת אינו יודע שהבקשה אינה באמת של הקורבן

<u>שאלה מספר 5:</u>

להלן טענות בהקשר של תהליך ה handshake של TLS/SSL. ביחרו את הטענה <u>הלא</u> נכונה.

א. לאחר שהלקוח העביר לשרת את המפתח המשותף הסודי בצורה מאובטחת (ClientKeyExchange), ה handshake מסתיים והצדדים יכולים מיד להעביר את המידע בצורה מאובטחת

ב. בתחילת ה handshake הלקוח מציע את האלגוריתמים שהוא תומך בהם לשרת ואת הגרסא המקס' שהוא תומך בה

ג. אם הלקוח רוצה handshake מקוצר, הוא שולח לשרת session id מחיבור קודם. אם השרת מסכים לhandshake מקוצר, הוא מחזיר את אותו session id שהלקוח שלח לו, אחרת, הוא שולח session id אחר

ד. אם הלקוח רוצה handshake חדש הוא שולח לשרת session id שווה לאפס, אחרת, שולח session id מחיבור קודם. אם השרת מסכים לhandshake מקוצר, הוא מחזיר את אותו session id שהלקוח שלח לו, אחרת, הוא שולח session id אחר

<u>שאלה מספר 6:</u>

פירצת cross site scripting נמצאת ב:

א. בקוד האתר הפגיע

ב. דפדפן

ג. שרת DB

ד. ב firewall

<u>שאלה מספר 7:</u>

מנגנון ה same origin policy ממומש ב:

א. דפדפן

ב. שרת אינטרנט

ג. שרת DB

ד. באפליקציה האינטרנטית

<u>שאלה מספר 8:</u>

חיטוי קלט הכי חשוב שיתבצע ב:

א. צד השרת

ב. צד הלקוח

ג. בדפדפן

ד. במחשבים ללא anti virus

<u>שאלה מספר 9:</u>

אליס ובוב רוצים לתקשר ביניהם בצורה מאובטחת, באופן כזה שאם X שולח הודעה, X לא יוכל לאחר מכן להתכחש שהוא שלח את ההודעה.

בכדי להשיג תקשורת שכזאת, עליהם להשתמש ב:

א. public key cryptography

ב. One Time Pad

ג. DNS

ד. כלל בייליויק

<u>שאלה מספר 10:</u>

איזו מבין הטענות הבאות נכונה?

א. ב PKI, שרת אינטרנט X שקיבל תעודה חתומה מ CA על ה public key שלו, אינו חייב ש ה CA שנתן לו (ל X) את התעודה יהיה ב root store של הלקוחות

ב. שימוש ב Syn cookies מונע התקפת XSRF

ג. הקמת חיבור TLS מחייבת שימוש בתעודה רק במקרה והחיבור מוקם בין שני שרתים

ד. ב TLS, שרת האינטרנט מייצר את התעודה עבור חיבור ה TLS

<u>שאלה מספר 11:</u>

חברה חדשה מציעה חומת אש הפועלת בטכנולוגיה הבאה:

חומת האש בודקת את כל כתובות ה source IP של החבילות שרוצות לצאת מתוך הרשת החוצה ובמידה והיא מוצאת כתובת IP שאחראית ליותר מ X אחוזים מהתעבורה בשעה האחרונה, היא אוטו' מוסיפה חוק שמסנן את כל החבילות מהכתובת הזאת למשך 24 שעות.

איזו מהטענות הבאות נכונה?

א. הטכנולוגיה עלולה לשבש את התעבורה התקינה, מפני שהיא עלולה לחסום מחשבים לגיטימיים שמייצרים הרבה תעבורה לגיטימית

ב. מחשב זדוני שנמצא בתוך הרשת אינו יכול להשתמש ב spoofed source ip - ולכן אינו יכול לגרום לחסימה של כתובות ip לגיטימיות

ג. הטכנולוגיה הנ"ל נותנת מענה כנגד התקפות המנצלות חולשה באופן שבו מומשה חומת האש

ד. הטכנולוגיה הנ"ל מונעת כל התקפה המנצלות חולשה במחשב שנמצא בתוך הרשת, למשל מחשב הפגיע ל Ping of death

<u>שאלה מספר 12:</u>

לחבילות בשכבת הרשת יש שדה IP-ID המשמש לפרגמנטציה. חבילות שונות (שאינן תוצאה של פרגמנטציה) נדרשות להיות עם IP-ID שונה כל אחת בתקשורת בין שני מחשבים. ישנן מ"ה אשר משתמשות במונה גלובלי אשר גדל ב1 על כל חבילה שנשלחת והערך של ה IP-ID הוא לפי מונה זה.

נתון מחשב A בשליטת תוקף ונתון מחשב V אחר אשר מ"ה שלו מממשת מונה גלובלי עבור IP-ID כפי שמוזכר לעיל. כמו כן, במידה ומחשב V מקבל <u>בקשת</u> פינג (ping) הוא משיב עליה <u>בתשובת</u> פינג (ping).

האם ניתן לגלות האם מחשב V תיקשר עם מחשבים אחרים במהלך פרק זמן מסויים?

א. כן. שולחים ping ל V מ A בתחילת פרק הזמן ושולחים ping נוסף ל V מ A בסוף פרק הזמן. בודקים את ההפרש בין ה IP-ID שהתקבל בכל אחד מהתשובות, ומסיקים (גדול מ1 ⇐ הייתה תקשורת עם אחרים בין לבין)

ב. כן. שולחים ping ל V מ A בתחילת פרק הזמן ושולחים ping נוסף ל V מ A בסוף פרק הזמן. אם קיבלנו בפעם השניה את אותו ה IP-ID שהתקבל בראשונה, סימן שלא הייתה תקשורת עם אחרים בין לבין

ג. לא. כדי לדעת דבר שכזה, חובה להחזיק חיבור TCP רצוף בין A ל V, ולכן מנגנון ה syn cookies ישבש את המונה

ד. לא. מנגנון ה same-origin-policy יחסום זאת

--- סוף המבחן ---